

격자 서명 HAETAE에 대한

오류주입공격과 감염형 무작위 검증 대응기법 (IRV)

서명 한 번의 오류로 비밀키가 새어 나온다 — 그리고 그것을 막는 무분기(branchless) 방어

HAETAE-120 / MODE2 · $z = y + (-1)^b \cdot \text{LN} \cdot (c \cdot s1)$

발표자 · 소속 · 날짜

BACKGROUND

배경 — HAETAE와 오류주입공격(FIA)

“수학적으로 안전해도, 실제 구현은 오류주입으로 뚫릴 수 있다.”

HAETAE

KpqC 격자 기반 전자서명 (Fiat-Shamir with aborts). 거부 샘플링 + 바이모달.

오류주입공격(FIA)

클럭·전압 글리치로 연산 중 상태를 교란해 오류 출력을 분석.

위협

단 한 번의 오류로 전체 안전성이 무너질 수 있음 → 구현자가 반드시 고려.

THE ONE LINE

급소 — 비밀키를 쓰는 유일한 연산

$$z1[i] = y1[i] + (-1)^b \cdot LN \cdot (c \cdot s1)[i]$$

$y1$ = 마스크(난수)

c = 공개

$s1$ = 비밀키

LN = 8192

정상 서명: 매번 다른 $y1$ 이 신호를 가려 $s1$ 이 보이지 않는다.

공격 표적: 이 줄의 곱셈($c \cdot s$)과 덧셈($+y$) — 마스크를 깨는 두 지점.

핵심: 정수 스케일 $LN=8192$ 는 나눗셈으로 정확히 되돌릴 수 있다(무손실). → 뒤에서 결정적.

FAULT POINTS

공격 지점 3종 — T1 / T2 / RB

지점	오류 효과	방출되는 z	누설
T1	$c \cdot s$ 곱셈 스킵	$z \approx y$ (난수 노출)	차분으로 $s1$ 복원
T2	$+y$ 덧셈 스킵	$z = c \cdot s1$ (비밀 직접)	★ 서명 1개로 $s1$ 복원
RB	거부 검사 스킵	경계 초과 z 방출	통계적 $s1$ 누설

T2가 헤드라인 — 다음 장에서 실제 숫자로.

LEAKAGE MAP

표 1 — 오류지점별 누설정보와 이용

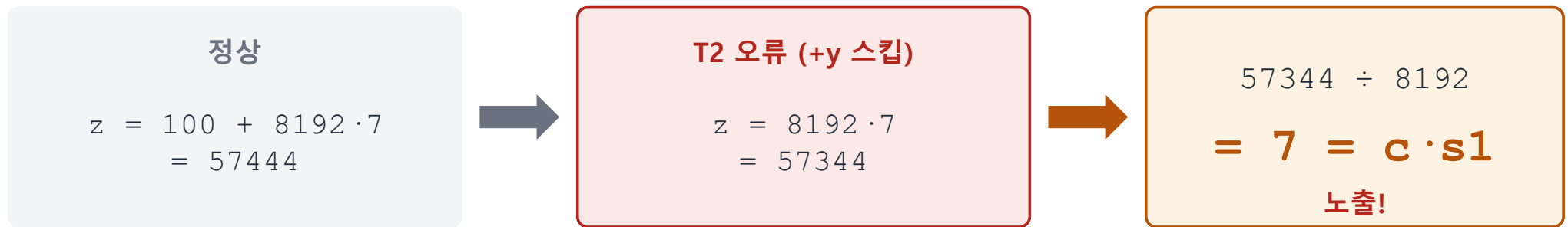
모든 공격 = 마스크 y 제거 $\rightarrow c \cdot s1$ 노출(c 공개). '서명 출력 수' = 공격에 필요한 서명 결과값 개수 (SCA 파형 아님)

	오류효과	누설정보	이용 $\rightarrow$ 추출	서명 출력 수
SEED	시드=0 $\rightarrow y$ 예측	난수 y	y 재현 $\rightarrow s1$	1
SIGNBIT	부호 b 반전	$s1$ (차분)	$2 \cdot c \cdot s1$ 차분 $\rightarrow s1$	2
UNPACK	공개행렬 A 변조	$s1$ (차분)	다른 c 차분 $\rightarrow s1$	2
LSB	LSB 스킵 $\rightarrow$ 다른 c	$s1$ (차분)	다른 c 차분 $\rightarrow s1$	2
T1	$c \cdot s$ 스킵 $\rightarrow z \approx y$	난수 y	$z \approx y$ 차분 $\rightarrow s1$	2
T2	$+y$ 스킵 $\rightarrow z = c \cdot s1$	s1 직접	$z/LN = \pm c \cdot s1 \rightarrow s1$	1
RB	거부 스킵 $\rightarrow$ 경계초과 z	통계적 키정보	다수 서명 통계 $\rightarrow s1$	다수

y 처리 4가지: ①알아낸다(SEED·T1) ②차분 상쇄(SIGNBIT·UNPACK·LSB) ③아예 없앤다(T2, 1개) ④은닉장치 무력화(RB, 통계)

IMPACT

T2 공격이 통하는 이유 — 실제 값



c 는 서명에 실려 공개 $\rightarrow \hat{s}1[k] = \text{NTT}(z/LN)[k] \cdot \hat{c}[k]^{-1} \pmod{q}$

$\rightarrow$ 오류 서명 단 1개로 768계수 100% 복원. 비결: T2의 z 는 LN의 정확한 배수라 나눗셈이 무손실 (정상 z 는 $57444 \bmod 8192 = 100 \neq 0$).

THE IDEA

IRV 아이디어 — “버리지 말고 감염시켜라”

기존 (탐지-후-중단)

“검사해서 다르면 버린다” (if 분기)
→ 그 if를 2차 오류로 또 건너뛰면 무력화

IRV (감염-후-무효화)

오류 흔적을 숫자 δ 에 모아 분기 없이 서명을 감염
→ 버릴 if가 없다

응답 z 확정



재계산·노름·시드
검사 → δ



$\delta = 0 \rightarrow$ 서명 그대로

$\delta \neq 0 \rightarrow$ 서명 난수화(무효)

버리는 if가 없다 → 그 분기를 건너뛰는 2차 오류가 성립하지 않는다.

MECHANISM M4

IRV가 T2를 잡는 법 — 재계산·비교 (M4)

핵심: 오류는 출력의 y 를 지웠지만, $y1$ 은 메모리에 그대로 남아 있다 → 다시 계산하면 정상값이 복원된다.

	방출된 $z1$	IRV 재계산 ($y1 + c \cdot s1$)	잔차 (XOR)
무결함	107	107	$107 \wedge 107 = 0$
T2 오류	7 (y 빠짐)	107 (정상 재계산)	$7 \wedge 107 = 108 \neq 0$

잔차 $\delta \neq 0 \rightarrow$ 다음 장의 “무분기 마스크”로 서명을 무효화. (펌웨어는 불일치 시 $\delta|=1$ 로 둬 — 값이 1이든 108이든 $\delta \neq 0$.)

THE TRICK

무분기 마스크 — if 없는 한 줄

```
factor = 0u - (uint8_t)((delta | (0u-delta)) >> 63);  
sig[i] ^= ks[i] & factor;    // ks = SHAKE256(비밀시드 ||  $\delta$  ||  $\mu$ )
```

$\delta = 0$ (무결함)

```
factor = 0x00  
sig ^= ks & 0x00 = sig  
→ 서명 그대로 (오탐 0)
```

$\delta \neq 0$ (결함)

```
factor = 0xFF  
sig ^= ks & 0xFF = sig ^ ks  
→ 서명 전체 난수화 (무효)
```

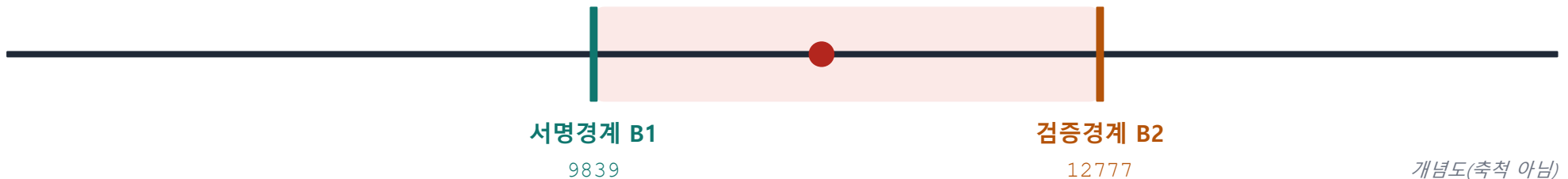
“0인가?”를 if 없이 전-0 / 전-1 마스크로 변환. 버릴 분기가 없으니 2차 오류의 표적도 없다.

THE TWO BOUNDS

RB와 두 경계 — 왜 $B1 < B2$ 인가

서명경계 $B1 = 9839$ (비밀 보호·빠빠) 검증경계 $B2 = 12777$ (위조 방지·느느)

RB가 흘리는 z (예: $\|z\|=10000$)



정상: 서명자가 B1로 다 거른다 → 이 "틈"의 z 는 존재할 수 없다.

RB: 거부 검사를 스킵 → 틈의 z 방출. 검증(B2)은 통과시켜 못 잡음(Lee-Ha).

IRV(M5): 검증경계가 아니라 서명경계 B1으로 재검사 → $10000 > 9839$ → 차단.

SECOND-ORDER

2차 오류 — 기존 방어가 뚫리는 이유

double-Lee-Ha는 main에서 "버리는 if"로 막는다:

```
if (mism) memset(g_sig, 0xFF, ...); // double: 두 결과 다르면 무효화  
if (bad)  memset(g_sig, 0xFF, ...); // leeha : 검증 실패면 무효화
```

2차 오류로 이 if 한 줄을 건너뛰면

무효화가 실행되지 않음
→ 누설 서명 그대로 방출 (뚫림)

IRV엔 버릴 if가 없다

$\text{sig} \wedge = \text{ks} \ \& \ \text{factor}$ 는 항상 실행
→ 2차 오류 성립 불가 (생존)

실측(2026-06-30): double-leeha 우회(LEAK), IRV만 차단(blocked).

RESULTS

비교 — IRV가 유일하게 세 가지를 동시에

	커버리지	RB 차단	2차 오류	서명시간
baseline	0 / 7	X	—	1.0×
double	7 / 7	✓	우회됨	2.0×
leeha	6 / 7	X	우회됨	1.14×
IRV (제안)	7 / 7	✓	생존	1.14×

IRV = 전면 커버리지(7/7) + 거부우회 차단 + 2차오류 생존 + 이중연산의 절반 비용. (코드·RAM은 double이 작아 트레이드오프.)

결론

*“오류를 탐지-후-중단하지 말고, 감염-후-무효화하라.
버릴 if가 없으면, 2차 오류도 없다.”*

- $z = y + c \cdot s1$ 한 줄에서만 비밀키를 쓴다 $\rightarrow +y$ 스킵 시 서명 1개로 키 복원 ($57344 \div 8192 = 7$).
- 기존 방어의 “버리는 if”는 2차 오류로 또 건너뛰면 무력화된다.
- IRV는 $\delta \neq 0$ 이면 서명을 통째로 난수화 — factor(0/0xFF)라는 분기 없는 한 줄.
- 검증경계가 아니라 서명경계(B1)로 다시 봐서 거부 우회까지 차단. 비용은 이중연산의 절반.